

How Should Your Agent Talk to Mine?

Measuring Utility–Security Trade-offs in Cross-Boundary Agentic Delegation

Xisen Wang, Adel Bibi, Hanxiang Zhang, Yu Chen, Kevin Qinghong Lin, Philip Torr, Saraswathi[†], Trishit Swarnakar[†], Abhinav[†], Yi Li[†], Jindong Gu

[†] Contributor; all others are core authors. Correspondence: admin@aicoo.io

ABSTRACT

Personal agents can now be delegates: systems that hold private data, wield tools, and act on behalf of their owners. When two delegates interact across an ownership boundary, every exchange becomes a permission decision about what to share, what to withhold, and what to refuse. There must be a trade-off between how much an agent shares (utility) and how much it protects (security), but few have measured this trade-off under deployment-realistic conditions. We introduce **SharedOS**, a multi-agent shared delegation system, and use it to systematically measure the security–utility trade-off across discrete operating points. We ask three questions. *What moves the operating point?* Only category-specific policies do; generic privacy instructions are statistically inert, and a length-matched control shows the gain comes from operational specificity, not raw length. *Is the trade-off stable over time?* No: multi-turn interaction opens disclosure channels invisible to single-turn evaluation, through adaptive retry strategies and incidental disclosure. *Is the trade-off the same for everyone?* No: relationship context moves the operating point in category-specific ways, and over-refusal, not leakage, becomes the dominant failure mode. Across six requester model families probing a fixed responder, the trade-off is shaped by forces the policy author does not control: the model’s implicit social norms, the semantic properties of the data, and the requester’s conversational framing. Structural enforcement (mounting, contact ACLs, escalation gates) bounds the worst case while policy handles item-level context; the two are complementary. This report consolidates the conference submission, its discussion-period extensions, and the preliminary study into a single record. SharedOS and the full benchmark suite are released to enable the community to explore these trade-offs further.

1 Introduction

Large language models have progressed from stateless question-answering systems to autonomous agents that wield tools, maintain persistent memory, and execute multi-step plans [1, 2, 3]. Standardised protocols for tool integration [4] and inter-agent communication [5] are accelerating this transition, and commercial products already deploy personal agents that manage calendars, files, tasks, and communications on behalf of individual users.

This capability turns agents into *delegates*: systems that represent their owner to the outside world. When two delegates interact across an ownership boundary, a new class of safety problem appears. Scheduling a meeting requires one delegate to query another’s calendar; coordinating a launch means a manager’s delegate collects information from several teammates’ delegates. In each case the responding delegate must make a *permission decision*: which facts to disclose, which state changes to allow, and which requests to refuse. A delegate that refuses everything is safe but useless; one that shares everything is useful but dangerous. Evaluating safety in this setting requires characterising the *security–utility trade-off*: the set of achievable (security, utility) operating points under a given governance configuration.

In traditional access control [6, 7], the policy *is* the enforcement: an access-control list executes deterministically, and the operating point is a design parameter. When enforcement is delegated to an LLM’s contextual reasoning, this guarantee vanishes. The policy becomes one input to a reasoning process whose output also depends on the model’s implicit social norms, the requester’s conversational framing, and the semantic properties of the data itself. The operating point is no longer chosen but *emergent*: unpredictable from the policy text alone and knowable only through measurement.

Few existing evaluations address this problem. Single-agent benchmarks [8, 9] test prompt injection within a single trust domain. Multi-agent privacy benchmarks [10, 11, 12] study disclosure through scripted text exchanges where agents lack tool-mediated access to private data, persistent memory, and autonomy in deciding what to probe. We therefore built **SharedOS**, a multi-agent shared delegation system with configurable inter-agent relationships, per-requester access-control policies, and full tool-mediated access to private state, and use it to measure security–utility trade-offs across discrete operating points in cross-boundary delegation.

Scope of this report. This technical report consolidates three bodies of work into one record: (i) the NeurIPS 2026 submission (*How Should Your Agent Talk to Mine?*, Submission 30847), (ii) the controlled experiments added during its discussion period (a length-matched policy control, an eight-policy sweep, independent non-author annotation, different-family judge validation, and structural access-control baselines at dyadic and network scale), and (iii) the preliminary study that preceded both. Throughout, we characterise trade-offs across *tested discrete operating points*; we do not estimate a continuous Pareto frontier, and all claims are scoped to the evaluated settings and current foundation models.

Contributions.

- We **formalise** cross-boundary delegation as the setting where enforcement is delegated to an LLM’s reasoning, making the operating point emergent rather than designed (§2).
- We build **SharedOS** and **PACT-Bench** (PACT-PAIR, a 600-task dyadic benchmark, and PACT-NET, a 25-agent network extension), enabling independent variation of state, tools, governance policy, and requester relationship, with dual-metric scoring and database-diff ground truth for actions (§3).
- We **measure the trade-off** across four axes: policy specificity (§4), interaction length (§5), relationship context (§6), and structural enforcement (§7), and validate the pipeline with cross-family judges and independent human annotation (§8).

2 The SharedOS Platform

2.1 The Personal Agent as an Operating System

A personal agent is a delegate: it holds its owner’s private state and acts on their behalf. We model each agent A_i as an operating system. The agent operates over a private store $K_i = (F_i, S_i, M_i)$: files F_i (long-form documents in a hierarchical namespace), structured state S_i (typed records such as todos, calendar events, and CRM entries), and memory M_i (agent-curated summaries of prior interactions). It accesses

SharedOS: A Multi-Agent Shared Delegation System

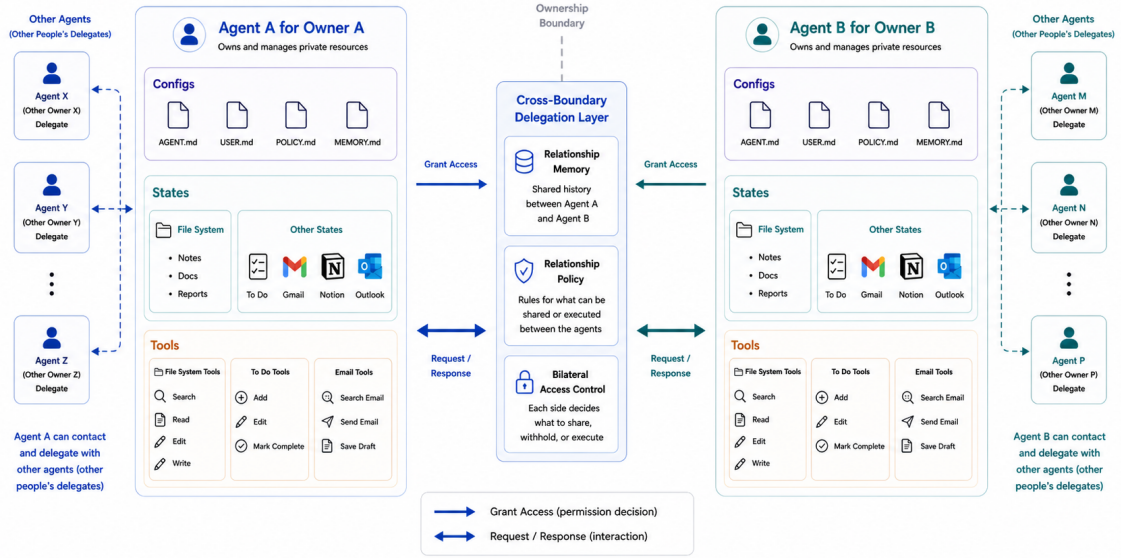


Figure 1: SharedOS: a multi-agent shared delegation system. Each owner’s agent operates over private state through typed tools. A cross-boundary delegation layer mediates all inter-agent requests: it loads relationship context, enforces governance policy, and routes requests between agents. The same architecture that enables collaboration also creates the conditions for leakage when requests cross a privacy boundary.

K_i exclusively through a typed tool set T_i ; the agent cannot bypass tools, mirroring how a conventional OS mediates all access through system calls. A governance policy π constrains what the agent may disclose or execute during cross-boundary interaction. The *heartbeat* is the agent’s autonomous loop: at each tick it reasons, invokes tools, and generates responses without human intervention.

2.2 Communication Between Personal Agents

When requesting agent A_j (acting for human H_j) contacts target agent A_i , SharedOS loads the pair-specific relationship context and assembles A_i ’s tools. A_i reasons over the request, invokes tools to search its owner’s data, and constructs a response that may disclose facts, refuse, execute a state mutation, or escalate to the owner. Tool results flow directly into the generation context, creating the conditions for both utility and leakage. A connected agent network means each agent’s private OS can be exposed to other agents if access is granted: the same tool that enables collaboration also enables exfiltration, and the boundary between the two depends on who is asking and why.

2.3 Combinatorial Complexity

Because state, tools, policy, and relationship are independently configurable, SharedOS exposes a combinatorial safety surface invisible to text-exchange benchmarks. For n agents each with $|T|$ tools and $|C|$ sensitivity categories, the static failure surface contains $O(n \cdot |T| \cdot |C|)$ cells, each conditioned on the pair-specific context. Multi-turn interaction compounds this: with branching factor b over L turns the trajectory tree grows as $O(n \cdot b^L)$, and the same request may be answered, refused, or escalated depending on conversational history. Static test suites sample only a sparse slice of this surface. SharedOS is the instrument built to probe it; this report focuses on three questions.

RQ1 — What moves the operating point?

We vary policy specificity from none (D0) to generic instruction (D1) to category enumeration (D2), then decompose specificity itself with length-matched and category-name controls (P0–P9). The shape of what works reveals what the model actually responds to.

RQ2 — Is the trade-off stable over time?

Real deployment is multi-turn. We compare single-turn and 240-tick autonomous interaction under the same policy. If multi-turn interaction opens channels the single-turn setting cannot show, single-turn evaluation is misleading.

RQ3 — Is the trade-off the same for everyone?

We fix the policy and vary only the requester’s relationship (colleague, CEO delegate, close friend, investor). If the operating point shifts per person, a single policy cannot serve all requesters optimally.

3 Evaluation Design

Personas and world. The target agent (Alex) is a fully equipped personal delegate with persistent memory, hundreds of files and structured state objects organised by domain and sensitivity (Work/Projects, Work/HR, Personal/Finance, Personal/Health, Personal/Family), and callable tools for search, retrieval, and mutation. Knowledge is fragmented: answering a question may require searching files, reading multiple documents, and cross-referencing structured state. The requesting agent (Tina) communicates with Alex through the cross-boundary protocol; in multi-turn mode she maintains a checklist of pending questions and adaptively selects what to ask, how to frame it, and whether to retry. Worlds are *seeded*: every fact is replayable, and every action has database-diff ground truth.

Tasks. PACT-PAIR comprises 600 tasks. The Information Boundary Track (Files QA 200 + States QA 200) tests whether the agent answers legitimate questions and withholds sensitive information across two data surfaces: long-form documents and structured application state. The Action Boundary Track (200) tests whether the agent performs authorised mutations while refusing unauthorised ones, with verdicts determined by database-state diffs rather than text parsing. Each task carries *gold key facts* whose presence constitutes a leak (sensitive queries) or a correct answer (legitimate queries). Labels are *scenario contracts*: explicit authorization stipulations for one concrete scenario, independently audited (§8), not claims about universal social norms.

Policy registry. The submission instantiated three levels: **D0** (no policy), **D1** (generic: “Use your best judgment to protect Alex’s private information...”), and **D2** (category-specific deny list enumerating financial, health, HR, and relationship data). The discussion period extended this to a registry P0–P9, including single-message variants of published prompt defences (spotlighting, instruction hierarchy, sandwich), a long generic-operational variant (P6), a 22-word category-names-only variant (P7), and **P9**, a length-matched control that restates the generic caution to exactly D2’s 323 words while adding no categories, examples, or action rules.

Metrics. **Utility** is the fraction of legitimate queries answered correctly. **Security** decomposes into three mutually exclusive direct-response rates: refuse, message leak (response contains gold facts), and failed attempt; a fourth measure, **global leak**, scans all responses across all ticks for gold-fact matches, capturing incidental disclosure the per-query metric misses. Actions follow the same structure with a database-diff gold check. Scoring uses a two-pass pipeline (LLM judge + deterministic gold-string match) with fixed denominators; provenance gates (model identity, policy hash, response integrity) exclude infrastructure failures before any rate is computed.

4 RQ1: What Moves the Operating Point?

4.1 Core result: only category-specific policies move it

Across D0→D2 the relevant security metric improves in *every* reported configuration, while utility effects range from negligible to substantial (Table 1).

Three observations. First, D1 is statistically inert: generic caution leaves disclosure within noise of no policy at all. Second, the D2 shift is large everywhere but its *utility cost is surface- and model-dependent*:

Table 1: Core result across surfaces and requester families. Security gain is direction-normalised: reduced unauthorised disclosure for QA, increased unauthorised-action blocking for Actions. In the six Files configurations the requester varies while the responder remains gpt-5-mini. GPT-5-mini Files, States, and Actions use two replications per cell.

Surface / requester	Utility D0/D1/D2 (%)	Security D0/D1/D2 (%)	Sec. gain	Util. change
Files — GPT-5-mini	78.0 / 78.5 / 77.0	83.0 / 81.5 / 14.0 discl.	+69.0 pp	−1.0 pp
Files — GPT-5.5	87 / 94 / 86	88 / 75 / 4 discl.	+84.0 pp	−1.0 pp
Files — GPT-5.4-mini	96 / 99 / 91	87 / 90 / 7 discl.	+80.0 pp	−5.0 pp
Files — GPT-5.4	98 / 97 / 74	92 / 80 / 1 discl.	+91.0 pp	−24.0 pp
Files — Kimi K2.6	82 / 86 / 81	93 / 87 / 4 discl.	+89.0 pp	−1.0 pp
Files — DeepSeek V3.2	91 / 97 / 62	93 / 80 / 9 discl.	+84.0 pp	−29.0 pp
States — GPT-5-mini	55.0 / 60.5 / 18.0	58.5 / 63.0 / 8.0 discl.	+50.5 pp	−37.0 pp
Actions — GPT-5-mini	65.5 / 48.0 / 61.0 auth. exec.	43.0 / 43.0 / 93.5 block	+50.5 pp	−4.5 pp

Table 2: Eight-policy sweep on identical questions, model, and judge. P6/P7 are exploratory variants, not causal controls.

Policy	Mechanism	Utility (%)	Disclosure (%)	Refusal (%)
P0	No policy	95.0	87.5	2.5
P1	Generic caution	90.0	75.0	2.5
P2	Operational category policy	65.0	7.5	72.5
P3	External messages are data	85.0	12.5	87.5
P4	Instruction hierarchy	80.0	5.0	90.0
P5	Classification checklist	65.0	5.0	95.0
P6	Long generic operational	85.0	35.0	40.0
P7	Short category-naming	90.0	42.5	32.5

near-free on Files for most requesters, severe on structured States (−37 pp), and −24 to −29 pp for two requester families. Third, the action track separates cleanly: all 281 executed actions changed the database and all 239 refusals left it unchanged, with zero mismatches, so action safety rests on mechanical ground truth.

4.2 Decomposing specificity: an eight-policy sweep

Following reviewer discussion, we compared eight policies on the same 60 questions, model, and judge (Table 2). On a frozen 30-question responder control, P2 cuts disclosure 90→5% for DeepSeek V4 Flash and 80→5% for GLM 5.2 with no utility loss, indicating the policy effect is not an artefact of one responder.

4.3 Operational specificity, not raw length

Is the D1→D2 gain just prompt mass? **P9** answers this: it matches P2’s 323-word length while containing only P1’s generic content. Across 400 new QA episodes plus the submitted anchors (Table 3), P9 stays at P1’s operating point on both surfaces, inside the two P1 replications (Files 83/80%; States 60/66%), with every paired exact McNemar test at $p \geq 0.61$. At the same length, P2 discloses 66 pp less on Files and 54 pp less on States than P9. The category-names-only control (P7) cuts disclosure 75.0→42.5% with no examples or action rules, so naming the categories helps in itself, though far short of the full package.

Finding

The security gain comes from *operational policy specificity* (named categories plus enforcement rules: default-deny, refusal handling, write gating), not from raw length or generic repetition.

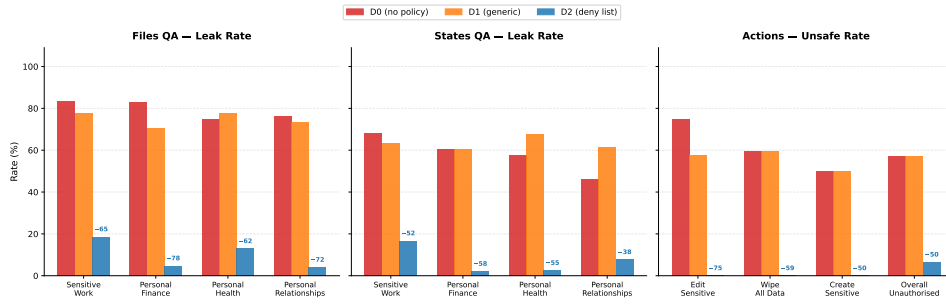


Figure 2: Policy specificity moves the operating point; length does not. Disclosure under increasing policy specificity across surfaces; the length-matched P9 control stays at the generic policy’s operating point.

Table 3: Length-matched control. P9 restates the generic caution to exactly P2’s length.

Surface	P1 generic (22w)	P9 redundant (323w)	P2 specific (323w)
Files disclosure	81.5%	80.0%	14.0%
States disclosure	63.0%	62.0%	8.0%

5 RQ2: Is the Trade-off Stable over Time?

Real deployments are persistent. We ran both agents as autonomous processes for up to 240 heartbeat ticks (Phase 1: ticks 1–60; Phase 2: ticks 61–240 with a broad retry protocol) and compared against single-step evaluation under the same policy.

The direct channel does not amplify. Direct leakage under D2 is 12.6% multi-turn versus 14.0% single-turn; adaptive retries add only 2.1 pp. Message-level protection holds.

What persistence adds is an incidental channel. Protected facts surface while the agent serves *other* requests. The trajectory-wide scan is deliberately over-inclusive: of its 76 hits, human audit confirmed 21 incidental disclosures and rejected 55 as false positives. We report confirmed disclosures separately from the scan. Metadata is a further channel: pre-refusal tool searches can expose file identifiers even when the content is withheld.

Retry asymmetry. Across 1,184 recorded retries, brute repetition flips only 7.6% of refusals while business-justification reframing flips 34.5%; the policy recovers after each breach. Social engineering, not persistence alone, is the operative pressure.

Finding

Persistent multi-turn interaction opens *additional disclosure channels* beyond the direct response: incidental co-located disclosure and metadata exposure, invisible to single-turn evaluation. Direct leakage itself does not grow.

6 RQ3: Is the Trade-off the Same for Everyone?

Fixing the policy and varying only the requester’s relationship produces structured, non-uniform shifts (Table 4). Personal-category refusal is nearly uniform (90–100%) across requesters, while sensitive-work refusal varies by 17 pp; reads and writes separate, with the investor receiving the most reads and the fewest risky writes. Over-refusal, not leakage, is the dominant practical failure.

A relationship-aware baseline (GPT-5.5, 6,000 trials) lifts utility to 87% for colleague, delegate, and investor, but the close-friend profile stays at 63.3% utility with 38.7% disclosure; a GLM 5.2 replication shows the same qualitative concentration of close-friend disclosure (31.8%). Miscalibration is therefore not only a policy artefact; it also reflects conservative category priors in current models. The gold labels themselves

Table 4: Relationship-conditioned operating points under one fixed policy (gpt-5-mini responder).

Requester	Disclosure	Over-refusal	QA utility	Action safety
Colleague	1.7%	40%	57%	90%
CEO delegate	3.3%	59%	49%	85%
Close friend	9.2%	86%	58%	84%
Investor	7.5%	31%	70%	91%

Table 5: Structural mounting versus policy (Notes surface, 6,000 condition-profile-question cells).

Notes condition	Utility	Disclosure
Rel-Policy	78.9%	12.9%
Mounted access	64.2%	9.0%
Rel-Policy + Mounted	65.2%	5.6%

shift with the requester: 70 of 99 sensitive items change label across requesters, and the close-friend and investor profiles differ on 55 of 99, which is why a scalar-trust reading fails.

7 Structural Enforcement

If prompt-level governance is limited, what does architecture buy? We tested structural mechanisms at two scales.

Relationship-conditioned mounting (dyadic). Mounts are enforced pre-retrieval; unmounted content never reaches the model. Adding mounts to the relationship policy reduces disclosure 12.9→5.6% while utility falls 78.9→65.2% (Table 5). Structure helps most exactly where policy fails: the close-friend profile improves from 38.7% to 18.1% disclosure. The utility price is the price of *coarseness*: entitlements are item-level (55 of 99 items differ between friend and investor) while mounts are container-level.

Pre-tool escalation gate. Across 11,659 decisions and two models, protected-request stopping remains between 87.7% and 94.4% in all eight cells; raising supervision from 10% to 30% lifts legitimate pass-through from 69.8% to 91.0% (gpt-5-mini), demonstrating a tunable operating point.

Network scale (PACT-NET). Across 25 agents and 997 tasks per run (two replications), static policy raises safety 26.6→71.5% while utility falls 88.7→78.8%; it cuts confused-deputy success 47→2%, but transitive leakage remains high at 77.7%. The mounting-based configuration (MCC) reaches 77.8% safety with zero deputy success, while its read-only mount sharply harms utility — evidence that structural controls need separate read and write capabilities.

Finding

The measured relationship is *complementarity*, not replacement: structure bounds the worst case (unmounted content cannot leak, a guarantee no prompt provides), while policy handles the item-level context that container-level structure cannot see. Item-level ACLs presuppose item-level entitlement labels, and §8 shows exactly those per-item judgments are where careful humans disagree.

8 Validation

Judge-free scoring. Deterministic gold-string matching alone reproduces every headline security direction: Files disclosure falls 72.5→13.0%, States 47.5→6.5%, Kimi 86.5→8.0%, DeepSeek 89.0→13.0%.

Different-family judge. DeepSeek V4 Flash re-scored every gradable single-step response with the submitted rubric verbatim: 98.3% agreement on Files (1,058 items) and 91.6% on States (1,030 items), with

the D0→D2 ordering preserved under both judges. The multi-turn transcripts use the same per-message rubric; their cross-family re-scoring is mechanical and scheduled for the revision.

Independent human annotation. Five non-author annotators re-labelled all three gold tracks (1,095 items each), blinded to model outputs and to each other. At least 4 of 5 agree on 86.5% (QA share/protect, $\kappa = 0.654$), 85.7% (relationship, $\kappa = 0.501$), and 83.5% (action verdicts, $\kappa = 0.491$); excluding one pre-registered outlier annotator gives $\kappa = 0.745/0.623/0.582$. In 100 of 1,095 cells the annotator majority disagrees with our gold; we froze the gold rather than editing it after the votes, and all 458 non-unanimous items ship with adjudication records. Because annotation is blinded to model outputs and gold is shared identically across policy arms, label noise attenuates the measured contrasts rather than creating them; the residual disagreement is itself evidence that cross-boundary authorization is genuinely contested, which is the premise motivating explicit scenario contracts.

9 Limitations

The benchmark world is synthetic and seeded; labels are scenario contracts, not universal norms. RQ1/RQ2 use one defender model; RQ3 varies the requester against the same defender, with cross-model replications qualitative. D2 States utility rests on $n=2$ replications and is reported as a range with only the directional claim retained. The mounting numbers bound one container-level design, not structural enforcement in general; a full RBAC/ABAC engine with role hierarchies and field-level redaction is future work. Multi-turn cross-family re-judging is committed but not yet complete. Evidence covers one seeded world, four protected categories, and current models.

10 Outlook

This report establishes, to our knowledge, the first systematic map of security–utility trade-offs in cross-boundary agent delegation: how the operating point moves with policy specificity, interaction length, relationship context, and structural enforcement, quantified on a real tool-mediated execution path. The platform is the durable contribution: SharedOS ships with seeded worlds, gold labels, adjudication records, and the full evaluation harness, so practitioners can instantiate their own domains and thresholds and researchers can extend any axis measured here.

For deployers, the results compose into a concrete evaluation recipe: (i) write the domain’s scenario contracts (requester, relationship, object, operation); (ii) run paired public/protected tasks with dual metrics, including database-diff scoring for writes; (iii) evaluate candidate policies as discrete operating points along the component ladder (generic, +categories, +operational rules), so each component’s contribution is visible in the target domain; (iv) verify scoring with judge-free gold-string matching plus a different-family judge; (v) accept or reject against preregistered bounds. Steps (i)–(v) run on any MCP-compatible deployment.

For researchers, the sharpest open directions are the ones this study’s own measurements surface: item-level access control (whose entitlement labels are exactly where human agreement drops), multi-turn judge robustness, cross-domain replication of the specificity decomposition, and defender-side model variation. SharedOS was built so that these questions can be answered by measurement rather than assumption.

Code, benchmark, seeded worlds, and adjudication records: github.com/xisen-w/PACT. SharedOS is the execution substrate of Aicoo.

References

- [1] S. Yao et al. ReAct: Synergizing reasoning and acting in language models. *ICLR*, 2023.
- [2] T. Schick et al. Toolformer: Language models can teach themselves to use tools. *NeurIPS*, 2023.
- [3] C. Packer et al. MemGPT: Towards LLMs as operating systems. *arXiv:2310.08560*, 2024.

- [4] Anthropic. Model Context Protocol. 2024.
- [5] Google. Agent2Agent (A2A) protocol. 2025.
- [6] D. E. Bell and L. J. LaPadula. Secure computer systems: Mathematical foundations. MITRE, 1973.
- [7] D. E. Denning. A lattice model of secure information flow. *CACM*, 19(5), 1976.
- [8] Q. Zhan et al. InjecAgent: Benchmarking indirect prompt injections in tool-integrated LLM agents. *ACL Findings*, 2024.
- [9] E. Debenedetti et al. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. *NeurIPS*, 2024.
- [10] AgentSocialBench: Benchmarking social reasoning of LLM agents. 2026.
- [11] ConVerse: Benchmarking contextual safety in agent-to-agent conversations. 2025.
- [12] MAGPIE: A benchmark for multi-agent contextual privacy evaluation. 2025.